

***Some vulnerabilities only
appear when the application is
actually running....***

What is DAST?

(Dynamic Application Security Testing)

- Security testing performed on a running application
- Simulates real-world attacker behavior
- Identifies vulnerabilities from the outside (black-box testing)

Why DAST is Important in Industry?

- Detects runtime vulnerabilities missed during static analysis
- Tests the actual deployed behavior of the application
- Helps identify:
 - Authentication flaws
 - Misconfigurations
 - Runtime security weaknesses

SAST vs DAST

SAST

- Scans source code
- Performed before deployment
- Finds coding issues early

DAST

- Scans running application
- Performed during/after deployment
- Simulates attacker behavior

Common Vulnerabilities

DAST Detects

- SQL Injection
- Cross-Site Scripting (XSS)
- Broken Authentication
- Security Misconfigurations
- Sensitive Data Exposure
- Missing Security Headers

What is OWASP ZAP?

- Open-source DAST tool developed by OWASP
- Used for:
 - Web vulnerability scanning
 - Security testing
 - Automated penetration testing
- One of the most popular DAST tools in DevSecOps

How OWASP ZAP Works?

AI-Driven DAST

DAST in CI/CD Pipelines

- Application deployed in test environment
- OWASP ZAP automatically scans application
- Vulnerabilities detected before production release
- Pipeline can:
 -  Pass
 -  Fail based on security findings

Security Gates with DAST

- Critical vulnerabilities → deployment blocked
- Medium/low risks → warnings or review required
- 📌 “No secure scan = No production deployment”

Real-World Importance